

Multipla", con l'indirizzo di 198 destinatari inserito nel campo "copia conoscenza" (cc), senza utilizzare il campo "copia nascosta" (bcc) per proteggere la riservatezza dei destinatari";

- "l'azienda ha comunicato che, a seguito di tale evento, è stata avviata una revisione delle procedure interne per garantire che in futuro vengano utilizzati i campi appropriati per la comunicazione di informazioni sensibili";

c) la pubblicazione sul sito web dell'Azienda di un documento contenente dati personali di un paziente, in particolare:

- "il documento, che riguardava un avviso di convocazione per una visita, è stato reso accessibile al pubblico per errore e successivamente rimosso, ma non prima che alcuni utenti avessero avuto accesso ad esso";

- "l'Azienda ha immediatamente attivato le procedure per la rimozione del documento e ha informato gli utenti interessati dell'accaduto, sottolineando l'importanza della protezione dei dati personali e delle misure adottate per evitare simili incidenti in futuro".

2. Le misure adottate

In risposta alle violazioni sopra descritte, l'Azienda ha adottato le seguenti misure:

a) "implementazione di un programma di formazione per il personale riguardante la gestione dei dati personali e la protezione della privacy, con particolare attenzione all'uso corretto degli indirizzi email e alla riservatezza delle comunicazioni";

b) "revisione e aggiornamento delle procedure interne relative alla gestione delle convocazioni e delle comunicazioni, per garantire che vengano seguite le migliori pratiche in materia di protezione dei dati";

c) "introduzione di controlli più rigorosi per la pubblicazione di documenti sul sito web dell'Azienda, inclusa la necessità di una revisione da parte di un responsabile della protezione dei dati prima della pubblicazione di qualsiasi documento contenente informazioni sensibili";

d) "attivazione di un sistema di monitoraggio per rilevare eventuali ulteriori violazioni dei dati e garantire una risposta tempestiva in caso di incidenti futuri".

3. Conclusioni

Alla luce delle informazioni fornite e delle misure adottate dall'Azienda, si ritiene che siano state intraprese azioni adeguate per affrontare le violazioni dei dati personali segnalate. Tuttavia, si raccomanda di continuare a monitorare l'efficacia delle misure implementate e di mantenere un dialogo aperto con l'Autorità per garantire la conformità alle normative vigenti in materia di protezione dei dati.

IL GARANTE

Pasquale Stanzione

Presidente

****Multiple**** with recipients the reference of 198 patients pertaining to the Multiple Sclerosis Center of ASST Ovest Milanese. The email, as per established practice, is always sent using the BCC (blind carbon copy) system of electronic mail, to allow the information to be sent to all recipients while blocking each of them from seeing the others. In this case, due to human error, the BCC system was not used; therefore, for each recipient, the email addresses of all the others were visible, some of which contain first and last names. Although no data related to the health status of each individual patient was disseminated, and thus without any indication of severity or state of the disease, the communication, also considering the attachment, was addressed to individuals pertaining to the Multiple Sclerosis Center;

- the violation concerned: "Email addresses provided by patients to the doctors who are treating them, in which, in some cases, first and last names are recognizable; Health data with reference to the fact that the recipients of the information contained in the email are those who pertain to the Multiple Sclerosis Center, without any specific references in the information itself to the health conditions of individual patients" (note of XX);

c) the delivery to a patient of health documentation also containing the result of an examination performed by a third party.

In particular, it was reported that:

- “the reporting lady collected the results of the tests performed the previous week at the Parabiago sampling center. Among the documents addressed to the lady, one relating to the result of another person's examination (interested party) with out-of-range values was mistakenly included. From the evaluations made, the error could be due to a redundant print, probably left in memory, of a single sheet produced multiple times in a previous phase. Neither the reporting lady nor the General Practitioner, nor the external specialist who took care of the lady noticed the error that caused the false diagnosis of pre-diabetes, triggering, on the indication of the treating physician, a series of specialist visits, blood sugar measurements twice a day, as well as the intake of supplements and diet, resulting in consequent states of anxiety”;

- “the violation occurred due to human error by the counter operator at the time of delivering the report, with the insertion of an examination result (one page) addressed to a person different from the one who made the report”;

- “the reports are delivered at the Reception counters following the user's presentation of the withdrawal request along with their identity card. The results of laboratory tests are printed only at the time of the request, in the presence of the requester and after verifying their identity. This method helps avoid the risk of paper documents being left on desks or accumulating prints. Furthermore, it is noted that the printed documents are numbered page by page in the following manner: “1/3”; “2/3”; “3/3” etc... and that they contain the indication of the name, surname, date of birth, and tax code of the person who underwent the examination, the date of acceptance and printing, as well as the requested identifier and the code of the requesting physician. There are also operational instructions aimed at ensuring the correctness of the procedures (...) (related to the technical and organizational measures adopted (or proposed for adoption) to prevent similar future violations). “During the year 2022, training courses were held aimed at preventing the risks of data violations owned by ASST Ovest Milanese”;

- “the data of the interested party whose confidentiality was violated are as follows: personal data (name, surname, tax code, date of birth) and health data concerning glucose and glycated hemoglobin values”;

- “the reporting lady has undergone a series of assessments and has carried out care activities that lasted throughout the holiday period, which also caused anxiety situations. It is true that this situation was also determined by the oversight of other professionals who did not notice the identity error in the report and continued their care activities. The reports, in fact, were composed and drafted correctly both in numbering and in heading, and nothing could have led them to the misunderstanding of confusing the results except for an erroneous view of the documentation. For the interested party, the violation materialized in the fact that their personal data were viewed by the reporting lady, but, to date, no negative consequences are noted against the interested party; rather, the reporting lady took care to anonymize the personal data of the interested party in the attached report sent to ASST. In any case, the interested party correctly received their report. In fact, they were contacted by telephone by the Head of the S.C. Laboratory Analysis, who verified that they had collected their report as occurred in fact”;

- the measures adopted to prevent similar future violations are “further training and awareness-raising activities for the operators who deliver reports to users and a review of specific risks in the context of report delivery. Operators will be reminded to pay maximum attention to comply with operational directive no. XX of XX (...), especially regarding the identification of those presenting the withdrawal form.

the report (interested party or delegate). As an additional corrective measure for laboratory tests with print on demand, it will be required to always perform – before the procedure of sealing the health document – a verification of the exact correspondence of the name indicated on the withdrawal and report form.

2. The investigative activity

The Office, regarding the aforementioned cases, based on what was represented by the data

controller in their respective notifications of violation, as well as subsequent evaluations, has notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the initiation of three proceedings for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, inviting the aforementioned data controller to submit defensive writings or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

In particular, respectively, with acts No. XX of XX, No. XX of XX, and No. XX of XX, the Authority has deemed that the Company has made three communications of health data concerning: 2 individuals, in the first case, in violation of the basic principles of processing referred to in Articles 5, 6, and 9 of the Regulation and Article 2-ter of the Code; 197 patients, in the second case, in violation of the basic principles of processing referred to in Articles 5, 6, and 9 of the Regulation and Article 2-ter of the Code; 1 individual, in the third case, in violation of the basic principles of processing referred to in Articles 5 and 9 of the Regulation and the security obligations referred to in Article 32 of the Regulation.

Considering that the violations subject to notification pursuant to Article 33 of the Regulation concerned the same data controller in relation to similar cases, the Office has ordered the consolidation of the 3 investigative proceedings, pursuant to Article 10, paragraph 4 of the Regulation of the Authority No. 1/2019, and has communicated this circumstance to the data controller with the aforementioned notes of XX and XX.

Subsequent to the aforementioned notifications of violations, the data controller submitted their defensive memoranda, pursuant to Article 166, paragraph 6, of the Code. In particular:

a) with reference to the first case described above (see point 1, letter a)), in a note dated XX, the Company stated that:

- “the nature of the violation consists in the loss of confidentiality as the citizen who received the summons for the visit to the Invalidity Commission of Magenta for their father reported having erroneously received the summons letter for the same day for two other individuals. At the time of the report, the severity of the violation was assessed as low since, in response to the complainant's report, the UOC Legal Medicine promptly contacted the interested parties so that they could still be informed of the summons. In this way, the UOC effectively prevented the failure to attend the same session. To date, there are no further consequences for the interested parties, who have not reported any discomfort and did not express any complaints during the telephone conversation. The duration of the violation is limited to the sending of the single summons letter by ordinary mail containing two other summons letters”;

- “despite having established procedures for the preparation of summonses, there was an error by an operator, in any case, not with malicious intent, also considering that the number of invitations sent annually at the level of the Intercompany Department of Legal Medicine ASST Ovest Milanese/Rhodense is approximately 20,000”;

- “the UOC Legal Medicine, upon receiving the report, immediately contacted the two individuals whose summons did not reach them by telephone, maintaining the time and date of the visit, to which they were able to attend regularly”;

- “at the time of the incident, on November 14th, the ‘Vademecum for Civil Invalidity Activities’ was in use at the intercompany department level, the revision of which as part of the continuous improvement and implementation of procedures represented one of the objectives of the department for 2021.

During an audit aimed at deepening the critical issues, it was agreed to integrate the aforementioned vademecum in the presence of all personnel at the Magenta office where the incident occurred. (...)

The critical event was nonetheless highlighted during the UOC meeting of medical staff held on XX and the administrative staff meeting held at the departmental level on XX”;

- the data involved in the violation are: “personal data, contact data, and health-related data in relation to the fact that they are personal data related to the activities of the Invalidity Commission. All summonses do not contain specific references to the health conditions of the summoned individual, but indirectly imply a possible condition of fragility, nonetheless related to the age of the individuals involved.”

[...]

b) in relation to the second case described above (see point 1, letter b)), in a note dated XX, the Company highlighted that:

- “the nature of the violation consists in the loss of confidentiality as each of the 198 patients, recipients of the email from the Multiple Sclerosis Center, had erroneously come to know the email addresses of all the others. It was an informational email regarding the administration of the third dose of the vaccine, which required timeliness and therefore there was a need to...

have certainty that the information had reached the patient. At the time of the report, the severity of the violation was assessed as medium, considering that individuals, as a result of the incident, could experience psychological and relational discomfort. To date, no reports in this regard have been received from any of the recipients of the email. The duration of the violation is limited to the mass sending of the email on XX to multiple recipients, which was followed, on XX, by an email from the Strategic Management with recommendations aimed at containing the impact of the original email and further phone calls made by individual doctors to all the affected patients to apologize and explain what happened. These interventions helped reassure the recipients of the email:

- “it was a mere material error by an operator, a typing mistake without evidence of negligence, incompetence, or gross fault on the part of the person who made it, nor was there any intent”;

- “an email was sent on XX from the Strategic Management to all interested parties with the apologies of ASST Ovest Milanese, asking them: 1) to refrain from disclosing the data, avoiding using the 'reply all' option to respond to the aforementioned email; 2) to delete the received email with the assurance that another would be sent shortly without the list of recipients visible; 3) not to archive, use, or disclose the data obtained through the email for any reason”;

- “the doctors who care for the affected patients contacted all of them by phone to explain what happened. Furthermore, the Director of the Complex Operational Unit of Neurology, during the audit held on XX with the entire Neurology UOC, among the improvement actions, established that email would no longer be used to send information of any type to groups of patients, but only single emails would be sent for specific responses to individual patients, deferring the development of other tools for group communications”;

- “immediately, the corporate privacy working group was convened for the day XX, after which two initiatives were decided: 1) instructions were given for the establishment of a centralized service for mass email sending and for the provision of dedicated areas on the corporate website for publishing notices and information aimed at groups of patients. Following this decision, on XX and on XX, the feasibility of activating a mass messaging service accessible to the entire Company was confirmed to Management, with the preparation of a specific procedure to ensure the protection of the privacy of those involved. This service can be activated when it is exceptionally necessary to ensure that the information reaches the patients, as the mere publication of information on the website is not sufficient. 2) a specific training course on privacy risks was organized for all members of the privacy working group held on XX, a training activity aimed at all internal data processing managers within the Company, which was proposed to be included in the corporate training plan for 2022”;

- “the General Director, during the Management Board meeting on XX, attended by the highest corporate executives, called for greater attention to activities that expose to behaviors in violation of privacy, inviting precise instructions to be given to staff and urging clarifications in case of doubt, communicating the intention to find a solution regarding the need to send mass communications”;

- “the shared and consolidated rule, provided by the Head of the UOC Neurology to his collaborators, is to send emails from the Multiple Sclerosis Center to recipients using BCC mode to avoid sharing the contact data used. Among the other technical and organizational measures in place, the principles stated in the corporate regulations on Privacy, in the IT regulations on the use of email, and the training that is provided annually to staff both in e-learning mode and to specific professional groups are included”;

- the categories of data involved are “personal data, contact data, and health-related data, the latter because the email is sent to those who are part of the Multiple Sclerosis Center, without specific references to the health conditions of individual patients being included in it”;

- “it was a material error of typing without evidence of negligence, incompetence, or gross fault on the part of the person who made it. This human act was the result of a 'slip' independent of any intention.

The written apologies expressed by ASST Ovest Milanese and the personal phone calls to all individual patients made by the doctors who care for them were understood by the interested parties, without any formal actions being taken by them to date. It is important to emphasize the significant workload that has burdened nursing and medical staff and, more generally, healthcare operators, resulting from the management of the pandemic. In particular, the timing of the anti-Sars-Covid vaccination campaign was very tight and close together, especially for vulnerable categories for whom there was a felt need to provide prompt, highly accessible information disseminated in a widespread manner. In this context, the human error of typing occurred that led to the incident subject to the report”;

c) with reference to the third incident above

described (see point 1, letter c)), with note of XX, the Company declared that:

- “the violation involved two individuals, one experiencing a loss of integrity and the other a loss of confidentiality. Regarding the individual for whom a loss of data integrity is established, there have been no reports of further negative consequences other than those indicated in the notification of XX. Following the aforementioned consequences, the lady had indeed submitted a request for reimbursement of the costs incurred for specialist visits and for the purchase of a 'glaucometer' valued at € 322, costs recognized by managerial determination no. 72 of 13/01/2023 (...);
- “as for the individual — the interested party — for whom a loss of confidentiality was established, at the time of notification, the reporting party had taken a careful approach to respecting the data of the interested party, anonymizing the personal data in the attached report sent to the ASST. Considering that at the time of notification, the Head of the SC 'Laboratory Analysis' had contacted the interested party by phone to ensure that they had received their report, there have been no further reports to date regarding negative repercussions from the incident”;
- “the event was caused by a negligent action that can be classified as 'mere human error'; in fact, although all precautions indicated in point 9 of the notification of XX were in place, it is not possible to reduce the risk of error to 100%, especially in a complex environment like that of ASST Ovest Milanese, where approximately 4,300 operators work, and moments of inattention, particularly during repetitive actions, are not absolutely predictable”;
- “regarding the case of loss of confidentiality concerning the interested party, as indicated above, it was immediately verified that they had received their report without experiencing any discomfort. As for the case of loss of integrity concerning the reporting lady, following an investigative verification at the Claims Evaluation Committee of the Company, reimbursement of the expenses incurred, as mentioned in point 1, was recognized for the amount of € 322”;
- “concerning the specific case, a note from the Director of SC Area Reception of XX (...) was issued, emphasizing the importance of always verifying: 1. The identity of the person presenting the report collection form; 2. The exact correspondence of the name indicated on the collection form and on the report. The new privacy regulation was updated with resolution 551 of 27/12/2022, which, in point 7.1.10 'report delivery', provides specific indications to ensure that this operation is carried out with the utmost respect for the rights of the user (...). This regulation, with note from XX, was disseminated by the company DPO to reinforce information to the company Delegates on some of the more relevant aspects of the regulation itself, including point 7, which also contains the section regarding report delivery, for targeted information also towards the collaborators of the Delegates (...). A note from the General Director of ASST Ovest Milanese of XX (...) disseminated the note from the President of the Data Protection Authority dated 27/01/23 to all Delegates for data processing to emphasize the necessity of the commitment of all operators in managing data, in care pathways, and in related activities, which is fundamentally based on respecting the dignity of individuals. The privacy working group was convened on XX (...) to draw the attention of its members to the contents of the data breaches that occurred in the company and to analyze them, to further raise awareness among all operators. Informative notes sent via email by the company DPO during 2022 (...) targeted, among other structures, the Medical Directors, Legal Affairs, the Services/Reception Area, highlighted excerpts from the annual report of the Authority of the Guarantor (...), aimed at emphasizing the

negative effects of errors that resulted in the exchange of reports and therefore of data between users. This was done to draw attention to the necessity of not underestimating this type of error, which can lead to harmful consequences for the user. For the 2023 training activity, a FAD project has been proposed for in-depth study and information on all the new policies recently adopted (Company privacy regulations — Del. no. 551 of 27/12/22, data breach regulation no. 554 of 27/12/2022, and Operational Instruction for issuing privacy information - IAP106) or soon to be issued. The company provisions concern the behaviors to be adopted, the forms to be used, and the roles defined based on levels of responsibility”;

- “this is a human error, moreover perpetuated by multiple subjects and professionals, including those external to the company. In fact, the incorrect care provided to the reporting lady was not prescribed by ASST Ovest Milanese, but by other specialist doctors and the general practitioner, all of whom have the obligation to verify the relevance, completeness, and consistency of the clinical information contained in the reports with the treatments provided to their patients”;

- “with reference to the meeting of the procedure in question (file no. XX with that initiated with note XX (prot. XX file no. XX) and with note of XX (prot. no. XX, file no. XX), it is highlighted that in light of the procedures existing at the time of the notified violations and all measures taken subsequently, the activity of preventing human error cannot guarantee its reduction to 100%. It is also noted that the other two

Episodes; which have led to the notification proceedings listed above, occurred with completely different dynamics from one another and were therefore not the result of a single "persevering" action, which could have appeared as a symptom of neglected attention. The activity of the ASST was nonetheless aimed at preventing the recurrence of erroneous actions;

- ***It is important to emphasize that, following the cessation of the state of emergency due to Covid, the ASST found itself significantly increasing the volumes of activities considering the necessity to initiate the recovery of the long waiting lists that had arisen due to the suspension/slowdown of activities during the two years of the pandemic. In fact, the Region set high production targets, resulting in operators significantly increasing volumes and work rhythms, and reorganization interventions became necessary, always characterized by a call for attention to "privacy" regulations.***

3. Outcome of the investigative activity

Taking into account what was represented and documented by the Company during the investigative proceedings, first with the acts of notification of violation and subsequently with the related defensive memos, it is observed that:

- **For "personal data," it is understood as "any information relating to an identified or identifiable natural person ('data subject') and for "data related to health," "personal data concerning the physical or mental health of a natural person, including the provision of health care, which reveals information related to their health status" (art. 4, par. 1, nos. 1 and 15 of the Regulation). These latter data deserve greater protection since the context of their processing could create significant risks for fundamental rights and freedoms (Recital no. 51 of the Regulation);**

- **Information about health status can only be communicated to the data subject and can be communicated to third parties only on the basis of an appropriate legal basis (art. 9 of the Regulation and art. 84 of the Code in conjunction with art. 22, paragraph 11, Legislative Decree of August 10, 2018, no. 101);**

- **The data controller is, in any case, required to respect the principles regarding data protection, among which is the principle of "integrity and confidentiality," according to which personal data must be "processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage" (art. 5, par. 1, lett. f) of the Regulation).**

- **Regarding the security of processing, art. 32 of the Regulation establishes that "taking into account the state of the art and the costs of implementation, as well as the nature, subject matter, context, and

purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk [...]” (par. 1) and that “in assessing the appropriate level of security, particular consideration shall be given to the risks presented by the processing that arise in particular from destruction, loss, alteration, unauthorized disclosure, or accidental or unlawful access to personal data transmitted, stored, or otherwise processed” (par. 2).**

4. Conclusions.

In light of the evaluations mentioned above, considering the statements made by the data controller during the investigation and given that, unless the act constitutes a more serious crime, anyone who falsely declares or certifies news or circumstances or produces false acts or documents in a proceeding before the Authority is liable under art. 168 of the Code "Falsehood in declarations to the Authority and interruption of the execution of the tasks or exercise of the powers of the Authority," the elements provided by the Company, as the data controller in the aforementioned defensive memos, although deserving of consideration, do not allow for overcoming the observations notified by the Office with the aforementioned acts initiating the proceedings, nor do any of the cases provided for by art. 11 of the Regulation of the Authority no. 1/2019 apply.

In particular, the arguments put forth by the Company are not suitable for accepting the requests for archiving made in the defensive memos. In fact, it is emphasized, as already highlighted on many other occasions by the Authority (see Decisions of the Authority of June 25, 2002, doc. web no. 29864 and June 24, 2003, doc. web no. 1132562, available at www.gpdp.it), that, in light of the definition of personal data mentioned above, email addresses fall under the notion of personal data and that, even if no indication was provided regarding the severity or illness of the patient, the circumstance that could be inferred from the context of the communications that the recipients were patients being treated at the multiple sclerosis center means that the treatments for which the notification of data breach was made to the Authority concerned information related to health, as they pertain to information regarding the provision of health care, which reveals information about the health status of the data subjects involved (art. 4, par. 1, no. 15 of the Regulation) (see, in this sense, decisions of the Authority of May 13, 2021, no. 206, doc. web no. 9688020, of September 16, 2021, no. 328, doc. web no. 9722297, of January 11, 2023, no. 7, doc. web no. 9861356, no. 7, of 28).

April 2022, no. 164, web doc no. 9779057, of July 7, 2022, no. 242, web doc no. 9809998, available at www.gpdp.it). This conclusion also applies in relation to the summons for a visit by the Company Commission for the assessment of civil disability, based on the medical documentation provided by the interested parties. Therefore, the sending of a communication via a single email message addressed to multiple recipients, whose addresses were clearly included in the carbon copy (c.c.) field, has, in fact, without justified reason and in the absence of a legal basis, mutually revealed to the recipients of the communications the health status of the other patients. Similarly, a communication of health data has also materialized in the behaviors described in the notifications of violations referred to in points 1. a) and 1. c). For these reasons, the preliminary assessments of the Office are confirmed, and the unlawfulness of the processing of personal data carried out by the Company is noted, for having communicated health data of the interested parties, in violation of the basic principles set out in Articles 5, letter f), and 9 of the Regulation and the obligations regarding security, as per Article 32 of the Regulation. The violation of the aforementioned provisions makes applicable, pursuant to Article 58, paragraph 2, letter i), the administrative sanction provided for by Article 83, paragraphs 4 and 5 of the Regulation, as also referenced by Article 166, paragraph 2, of the Code. In this context, considering, in any case, that the conduct has exhausted its effects and considering that the Company has declared to have adopted further measures deemed necessary to prevent future similar occurrences, the prerequisites for the adoption of measures, of a prescriptive or prohibitory nature, referred to in Article 58, paragraph 2, of the Regulation do not exist.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code). The violations of Articles 5, paragraph 1, letter f), 9, and 32 of the Regulation, caused

by the conduct carried out by the Company, are subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraph 5, of the Regulation. It should be noted that the Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case," and, in this context, "the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Guarantor's Regulation no. 1/2019). The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and dissuasiveness, indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided for in Article 83, paragraph 2, of the Regulation in relation to which, for the cases in question, it is observed that: the Authority became aware of the events following the notifications of personal data violations made by the data controller and no complaints or reports were received by the Guarantor regarding the incident (Article 83, paragraph 2, letters h) and k) of the Regulation); the data processing carried out by the Company also involved data capable of revealing health information about approximately 200 interested parties (Article 83, paragraph 2, letters a) and g) of the Regulation); from the perspective concerning the subjective element, no intentional attitude on the part of the data controller emerges, as the violations occurred due to errors by authorized personnel (Article 83, paragraph 2, letter b) of the Regulation); the Company has addressed the issue by introducing further measures aimed at reducing the replicability of the same events that occurred (Article 83, paragraph 2, letter c) of the Regulation); the data controller has demonstrated a high degree of cooperation with the Authority in order to remedy the violations and mitigate their possible negative effects (Article 83, paragraph 2, letter f) of the Regulation); the facts occurred, in one case, during the vaccination campaign and the need to provide updated recommendations on Covid-19 to patients with multiple sclerosis as quickly and easily as possible; in another case, following the end of the Covid-19 state of emergency, to increase the volume of activities and work pace, in order to address the long waiting lists that arose due to the suspension and slowdown of activities during the pandemic period, with consequent reorganization interventions (Article 83, paragraph 2, letter k) of the Regulation). In light of the aforementioned elements, assessed in their entirety, it is deemed appropriate to determine the amount of the pecuniary sanction provided for by Article 83, paragraph 5, of the Regulation, in the amount of €12,000.00 (twelve thousand) for the violation of Articles 5, paragraph 1, letter f) and 9 and 32 of the Regulation, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportional, and dissuasive. It is also considered that the accessory sanction of publication on the Guarantor's website of this provision should be applied, as provided.

from Article 166, paragraph 7, of the Code and Article 16 of the Regulation of the Authority No. 1/2019, also considering the type of personal data subject to unlawful processing.

It is noted, finally, that the conditions referred to in Article 17 of the Regulation of the Authority No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Authority, are met.

ALL OF THE ABOVE, THE AUTHORITY

declares the unlawfulness of the processing of personal data carried out by the Territorial Social Health Company (A.S.S.T.) Ovest Milanese, for the violation of Articles 5, paragraph 1, letter f) and 9 and 32 of the Regulation, as specified in the reasoning.

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the Territorial Social Health Company (A.S.S.T.) Ovest

Milanese, with its registered office in Legnano, Via Papa Giovanni Paolo II C.P. 3, 20025, VAT and Tax Code: 09319650967, represented by the legal representative pro tempore, to pay the sum of €12,000.00 (twelve thousand) as an administrative monetary fine for the violations indicated in this provision; it is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed fine.

ORDERS

the aforementioned Territorial Social Health Company (A.S.S.T.) Ovest Milanese, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €12,000.00 (twelve thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement actions in accordance with Article 27 of Law No. 689/1981.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Authority's website and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Authority, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to file a judicial appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, July 18, 2023

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Stanzione

THE SECRETARY GENERAL

Mattei